

Checklist

Security Policies

Policy Foundation

- ☐ Define why the policy is needed and what security objective it supports.
- ☐ Ensure the policy promotes consistent behavior across the organization.
- ☐ Make the policy accessible so employees can understand applicable rules.
- ☐ Clearly define expectations, boundaries, and prohibited behavior.
- ☐ Confirm the policy supports applicable regulatory, compliance, and audit requirements.
- ☐ Ensure the policy reflects the organization's overall security posture.
- ☐ Obtain appropriate management endorsement.

Policy Language

- ☐ Write clear, simple, and concise policy statements.
- ☐ Focus policies on **what must be achieved**, leaving detailed implementation steps to procedures or standards.
- ☐ Use strong terms such as **must**, **will**, **shall**, and **do** when requirements are mandatory.
- ☐ Avoid ambiguous terms such as **should**, **try**, and **mostly** for mandatory requirements.
- ☐ Clearly document any permitted exceptions.
- ☐ Avoid unnecessary legalese or excessively wordy statements.
- ☐ Use short paragraphs or bullet points where appropriate.

Required Document Contents

- ☐ Include a version number.
- ☐ Include an effective date.
- ☐ Include a revision history or summary of changes.
- ☐ Identify the policy owner.

- ☐ Identify the policy approver.
- ☐ Define roles and responsibilities for implementation, monitoring, compliance, and updates.
- ☐ Include executive sign-off where required.
- ☐ Provide a brief purpose or overview.
- ☐ Clearly define the scope and who or what the policy applies to.
- ☐ Include the actual policy statements and requirements.
- ☐ Reference related policies, standards, procedures, processes, and forms.
- ☐ Reference relevant regulatory, legal, or compliance requirements where appropriate.
- ☐ Use consistent document and artifact naming conventions.

Policy Coverage

- ☐ Acceptable use
- ☐ Access control and remote access
- ☐ Password construction and protection
- ☐ Encryption and key protection
- ☐ Email and communications
- ☐ Internet usage
- ☐ Mobile devices
- ☐ Removable media
- ☐ Wireless communications
- ☐ Software installation
- ☐ Workstation security
- ☐ Server security and auditing
- ☐ Router, switch, and network security
- ☐ Malware and antivirus protection
- ☐ Web application security
- ☐ Incident response and recovery
- ☐ Data breach response
- ☐ Disaster recovery
- ☐ Risk assessment
- ☐ Security awareness and social engineering
- ☐ Data/database credentials
- ☐ Logging
- ☐ Equipment acquisition and disposal
- ☐ Employee and third-party responsibilities

- ☐ Ethics and intellectual property
- ☐ Any industry-specific or regulatory policies required by the organization

Policy Management

- ☐ Create separate, manageable policy documents rather than one large document where practical.
- ☐ Align policies with an appropriate security framework or regulatory regime.
- ☐ Store policies in a central and easily accessible location.
- ☐ Use revision control so the current approved version is identifiable.
- ☐ Establish a formal review and approval process.
- ☐ Communicate new and revised policies to affected personnel.
- ☐ Keep backup copies of policies needed during outages or disaster recovery.
- ☐ Maintain physical copies of critical policies when digital access may be unavailable.

Review and Maintenance

- ☐ Treat policies as living documents.
- ☐ Review policies at least annually or according to the organization's review schedule.
- ☐ Review policies after significant business, technology, regulatory, or security changes.
- ☐ Update outdated requirements and references.
- ☐ Record what changed during each revision.
- ☐ Obtain required approval for revised policies.
- ☐ Verify policies remain aligned with current business objectives and the operating environment.
- ☐ Remove or archive obsolete versions so users do not follow outdated requirements.